



INFORME TÉCNICO: Análisis del Ciberataque a Equifax (2017)

FACULTAD DE INGENIERÍA- UPC

CURSO: Fundamentos en Ciberseguridad

CICLO: 2026-02

SECCIÓN: NRC 7629

PROFESOR: Miranda Quezada, Carlos Enrique

INTEGRANTES:

MIÑANO PEÑA, Gianmarco (U20250711)

1. Introducción

La ciberseguridad contemporánea ha demostrado que la adquisición de tecnología por sí sola no elimina el riesgo digital; es indispensable contar con una gobernanza sólida que coordine de manera efectiva los procesos, las personas y los sistemas. Cuando esta alineación falla, las consecuencias escalan rápidamente desde una alerta técnica hasta una crisis institucional. El presente informe analiza la brecha de datos sufrida por Equifax en 2017, uno de los incidentes cibernéticos más severos de la historia. A través de la evaluación de las vulnerabilidades explotadas, el impacto en la Tríada CIA y las fallas organizativas subyacentes, se exponen lecciones críticas sobre la importancia de la gestión proactiva de activos y la mitigación de vulnerabilidades.

2. Descripción del Incidente y Vector de Ataque

En septiembre de 2017, Equifax, una de las principales agencias de reporte de crédito a nivel global, anunció que ciberdelincuentes se habían infiltrado en su red corporativa, exponiendo la información personal de aproximadamente 147 millones de consumidores (Federal Trade Commission [FTC], 2019).

A diferencia de los ataques que dependen de la manipulación psicológica, como el *phishing*, este incidente se originó a través de un vector de ataque puramente técnico. Los atacantes localizaron un servicio web expuesto —el portal de disputas en línea de la compañía— que operaba con software desactualizado. Al identificar esta superficie de ataque, aprovecharon la conectividad directa a internet para penetrar en los sistemas internos, demostrando que un solo punto ciego en el perímetro es suficiente para comprometer toda una infraestructura (U.S. Government Accountability Office [GAO], 2018).

3. Vulnerabilidades Explotadas: La anatomía de un "N-day"

El núcleo de la infiltración a Equifax no fue un ataque sofisticado de día cero (*Zero-day*), sino la explotación de una vulnerabilidad N-day. En ciberseguridad, un N-day ocurre cuando los atacantes explotan una debilidad conocida para la cual el fabricante ya ha publicado un parche, pero que la organización víctima aún no ha implementado en sus sistemas.

La vulnerabilidad específica fue catalogada como CVE-2017-5638 en la base de datos nacional (National Institute of Standards and Technology [NIST], 2017). Esta falla afectaba al *framework* de código abierto Apache Struts, permitiendo a los atacantes ejecutar código de forma remota (RCE) mediante la inyección de comandos en los encabezados HTTP. Aunque la Fundación Apache publicó el parche en marzo de 2017 y el Departamento de Seguridad Nacional de EE. UU. alertó sobre su criticidad, los procesos internos de Equifax fallaron. Según el informe del Congreso estadounidense, la compañía carecía de un inventario completo de sus activos de software, lo que impidió a los equipos de seguridad identificar qué sistemas utilizaban la versión vulnerable de Apache Struts (GAO, 2018). Esta negligencia operativa ilustra a la perfección el riesgo descrito en la categoría A06: Componentes vulnerables y desactualizados del OWASP Top 10 (OWASP, 2021).

4. Análisis de Impacto (Tríada CIA)

El ataque superó rápidamente la fase de acceso inicial, propagándose por la red y devastando los pilares fundamentales de la seguridad de la información:

- **Confidencialidad (Impacto Crítico):** Fue la propiedad más afectada. Los atacantes extrajeron bases de datos enteras que contenían nombres, fechas de nacimiento, números de Seguro Social y, en algunos casos, datos de tarjetas de crédito y licencias de conducir. Esta exposición masiva violó la privacidad de millones de personas y resultó en multas y acuerdos de conciliación por cientos de millones de dólares (FTC, 2019).
- **Integridad (Impacto Alto):** La integridad del entorno se vio comprometida cuando los atacantes, tras explotar el RCE, instalaron *web shells* (scripts maliciosos que actúan como puertas traseras). Estas herramientas alteraron el estado legítimo de los servidores web de la empresa, permitiendo a los delincuentes enviar comandos ocultos y mantener persistencia en la red durante meses sin ser detectados (GAO, 2018).
- **Disponibilidad (Impacto Moderado):** Si bien el objetivo de los atacantes no era destruir ni secuestrar los datos mediante *ransomware*, la disponibilidad de los servicios de Equifax sufrió un impacto colateral. Al descubrirse la brecha, la organización tuvo que dar de baja el portal de disputas y aislar múltiples bases de datos críticas para contener la amenaza y realizar las investigaciones forenses pertinentes, interrumpiendo las operaciones normales.

5. Medidas de Mitigación y Resiliencia

La magnitud del desastre de Equifax subraya que la prevención no depende únicamente de instalar barreras perimetrales, sino de mantener una higiene tecnológica constante. Las medidas de mitigación necesarias para evitar este tipo de incidentes abarcan:

1. **Gestión Dinámica de Vulnerabilidades y Activos:** Es imperativo abandonar los escaneos esporádicos en favor de un inventario en tiempo real. Las organizaciones deben saber exactamente qué software corre en su red (Listas de Materiales de Software o SBOM) para poder priorizar y aplicar parches críticos inmediatamente después de su publicación, cerrando la ventana de exposición N-day.
2. **Segmentación de Red y Mínimo Privilegio:** Los atacantes lograron moverse lateralmente por la red de Equifax porque el servidor web vulnerado tenía acceso directo a bases de datos históricas no relacionadas con su función. Aislar los sistemas expuestos a internet y restringir estrictamente los privilegios de conexión limita el alcance del daño si el perímetro es vulnerado (GAO, 2018).
3. **Inspección de Tráfico y Trazabilidad:** El ataque en Equifax pasó desapercibido durante 76 días en gran parte porque el certificado de seguridad utilizado para inspeccionar el tráfico de red interno había expirado (GAO, 2018). Mantener un monitoreo activo, renovar las herramientas de inspección SSL/TLS y correlacionar *logs* es vital para detectar anomalías y detener la exfiltración antes de que se complete el robo.

6. Conclusión

El ciberataque a Equifax es un hito educativo que demuestra cómo un fallo administrativo puede eclipsar cualquier inversión en tecnología defensiva. La incapacidad de la empresa para inventariar su software y aplicar un parche disponible para una falla crítica (CVE-2017-5638) transformó un riesgo completamente mitigable en una catástrofe histórica. Este caso confirma que la ciberresiliencia no es un estado estático, sino un ejercicio continuo de visibilidad,

disciplina operativa y gobernanza de TI, donde la rápida respuesta ante vulnerabilidades conocidas marca la diferencia entre un intento fallido y un compromiso total.

7. Referencias

Federal Trade Commission (FTC). (2019, julio). *Equifax Data Breach Settlement*. U.S. Federal Trade Commission. Recuperado de <https://www.ftc.gov/enforcement/cases-proceedings/refunds/equifax-data-breach-settlement>

National Institute of Standards and Technology (NIST). (2017). *CVE-2017-5638 Detail*. National Vulnerability Database (NVD). Recuperado de <https://nvd.nist.gov/vuln/detail/CVE-2017-5638>

Open Worldwide Application Security Project (OWASP). (2021). *A06:2021 – Vulnerable and Outdated Components*. OWASP Top 10. Recuperado de https://owasp.org/Top10/A06_2021-Vulnerable_and_Outdated_Components/

U.S. Government Accountability Office (GAO). (2018, agosto). *Data Protection: Actions Taken by Equifax and Federal Agencies in Response to the 2017 Breach* (Report No. GAO-18-559). Recuperado de <https://www.gao.gov/products/gao-18-559>